SECURITY · AUTOMATION

Key Ceremony — Loop Review Checklist (Automation)

A recurring, **non-custodial** review checklist that continuously attests the key-management lifecycle — the QA/Compliance *verify* lane run as an agent loop. Verify only; never mint.

Version: **1.0** Date: **2026-06-22**

Companion to: **KEY-MANAGEMENT-LIFECYCLE.md (§8 rotation, §9 ceremony, §10 glossary, §12 ownership)**

Run mode: **recurring automated review (e.g. Claude Code /loop), non-custodial — verify only**

---

0. Purpose & guardrail

A recurring agent loop that **continuously attests** the key-management posture of the stack without ever touching a secret. It is the automation embodiment of the QA/Compliance *verify* lane in the Interactive Key Ceremony (`KEY-MANAGEMENT-LIFECYCLE.md` §9.7).

> **Non-custodial guardrail (hard rule).** This loop **verifies by side-effect** — HTTP status, masked previews, fingerprints, file *presence*. It **never reads, prints, or stores a secret value.** Any check that would require seeing a key is **out of scope** and must be handed to the Deployment Officer (human). A finding is *reported*, never *remediated* by the loop (remediation = a privileged write = human-only, §9.1).

Cadence: daily lightweight scan; full review weekly; mandatory run after any deploy, scope change, or incident. Cadence triggers map to PMO ownership (§12.2).

Escalation routing (RACI, §12): `WARN` / `FAIL` → **Compliance Officer** (attest) + **PMO** (schedule remediation ceremony). PII-plane findings → **DPO**. Execution →

Deployment Officer. `A` for residual risk → **CISO**.

---

1. Rotation cadence compliance (§8.1)

☐ **Root ADMIN_KEY** within rotation window (annual / personnel-change). — *check:* last `executed_by` rotate record date < 365d.

☐ **Rotatable / delegate key** within window (quarterly / team-change). — *check:* audit record date < 90d.

☐ **JWT_SECRET** within window (annual). — *check:* audit record date.

☐ **Shopify Admin token** auto-rotation healthy (not expired/stale). — *check:* `GET` a cheap authed endpoint → `200`; not `401/502`.

☐ No credential **past its cryptoperiod** (§10). — *check:* every key in §2 inventory has a dated rotation record.

2. Audit-trail integrity (§9.4)

☐ Every ceremony since last review has **one append-only record**. — *check:* record count delta ≥ ceremony count.

☐ Each record carries **fingerprints only** (`sha256[:8]`), **no key values**. — *check:* grep records for anything key-shaped → must be **zero**.

☐ Each record names **distinct** `executed_by` vs `verified_by` (SoD, §9.7.1). — *check:* fields differ.

☐ `old_fp → new_fp` present and **different** for every rotate. — *check:* fingerprints not equal.

☐ `reason`, `overlap_window`, `consumers_updated` populated. — *check:* no empty fields.

3. Exposure scan — `.env` / CLI / git (§9.6)

- ☐ **No real secrets in any `.env` / `.dev.vars`** committed to git. — *check:* `git log` / `git grep` for secret patterns → zero; `.dev.vars` git-ignored.
- ☐ **No secret in shell history or tool logs** from inline use. — *check:* scan for inline `Bearer` / `sk_` / `re_` /key= patterns → zero.
- ☐ **Cloudflare secrets are write-only** (read-back masked). — *check:* read endpoint returns mask/`(set)`, never a value.
- ☐ **Local key dotfiles** exist and are `chmod 600`. — *check:* file *presence* + perms only (never `cat`).
- ☐ No secret echoed into the **transcript/context** during this run. — *self-audit:* loop emitted zero raw values.

4. Least privilege & scope of compromise (§10, §11)

- ☐ **Shopify GraphQL token** scoped to only used `read_*` / `write_*` — no unused scopes. — *check:* granted scopes vs call inventory.
- ☐ **Tenant tokens** (`crm_t_*`) are shop-scoped; none carry admin scope. — *check:* token metadata.
- ☐ **Market site tokens** stored apart from config, write-only, one-site blast radius. — *check:* `GET /admin/markets` shows `(set)` flag only.
- ☐ **GA4** `api_secret` server-side only; never shipped to the browser. — *check:* not present in any client bundle.
- ☐ No long-lived, broad token where an expiring/scoped one exists. — *check:* inventory review.

5. Roles, SoD & ownership (§9.7, §12)

- ☐ **Executor ≠ attester** held by distinct people this period. — *check:* audit `executed_by` vs Compliance sign-off identity.
- ☐ Every reviewed activity has **exactly one Accountable**. — *check:* RACI rows (§12.2).
- ☐ **DPO consulted** on any ceremony touching `JWT_SECRET` / `XANO_API_KEY`. — *check:* PII-plane records carry DPO approval.
- ☐ **Agent (this loop) is non-custodial** — appears only as verify/record support. — *self-audit:* no `R` / `A` write performed.

6. Migration-specific health (§11)

- ☐ **Shopify:** GraphQL Admin calls server-side only; token never client-exposed. — *check:* no token in browser/network from client.
- ☐ **Shopify:** platform token expiry/auto-rotation succeeding (no dead-refresh loop). — *check:* recent self-heal success in logs.
- ☐ **Google:** GA4 server-side `api_secret` present, write-only, rotated per schedule. — *check:* `(set)` flag + rotation date.
- ☐ **Google:** Consent Mode v2 gate intact before ad-signal credential use (EEA). — *check:* consent gate present.
- ☐ **Agentic codegen** that touched GraphQL/integrations introduced **no inline secret**. — *check:* diff scan since last review.

---

7. Loop output contract

Each run emits a single fingerprint-only summary (safe to publish):

```
date:        <UTC>
run_by:      agent:loop-review
scope:       [cadence, audit, exposure, least-priv, roles, migration]
result:      PASS | WARN | FAIL
findings:    <count> ( <n> WARN, <n> FAIL )
escalated_to: [compliance?, pmo?, dpo?, deployment-officer?]
secrets_seen: 0            # MUST always be 0 — non-custodial invariant
next_run:    <UTC>
```

Stop conditions: any `FAIL` halts the loop and pages the routed owner (§12). The loop **never** attempts remediation — it opens a ceremony request and exits.

---

8. Example `/loop` invocation

```
/loop 1d Review docs/KEY-CEREMONY-LOOP-REVIEW.md against the live stack.
Verify by side-effect only — never read or print a secret. Emit the §7 output
contract; on any FAIL, stop and route per §12. secrets_seen must be 0.
```
